

Improving LLM-Driven Automated Penetration Testing Systems

胡译文

信息安全专业
同济大学

2026 年 5 月 9 日

渗透测试的挑战与自动化需求

安全形势

- 全球渗透测试市场：2020 年 \$17B → 2025 年预计 \$45B
- 传统渗透测试依赖人工，频繁切换 Nmap、Metasploit 等工具，流程割裂
- 从业者专业要求高，测试成本居高不下，难以规模化

研究基础：AutoPT 与 PSM

- Wu 等人的 AutoPT^[1] 引入渗透测试状态机 (PSM)，以有限状态机约束 LLM 决策空间
- PSM 将 Scan → VulnSelect → Inquire → Exploit → Check 五个阶段串联为自动化测试链路
- 本文以 AutoPT 为基础，针对三方面不足进行改进

AutoPT 的主要局限

五个核心问题

- ❶ 只扫默认端口 (**80**): 非标准端口服务 (Elasticsearch 9200、Tomcat 8080) 大量漏检
- ❷ 转移条件固定: 扫描无漏洞时仍继续执行 Inquire 和 Exploit, 资源浪费
- ❸ 缺浏览器表单交互能力: 安装向导、下拉框等多步骤场景无工具可用
- ❹ **ReAct** 解析器零容忍: 思维链模型输出 <thinking> 标签导致解析失败直接终止
- ❺ 仅命令行界面: 缺少图形化管理, 可用性受限

本文三大改进方向

(1) PSM 流程控制优化 (2) Agent 工具扩展与容错增强 (3) Web Console 图形化界面

系统总体架构

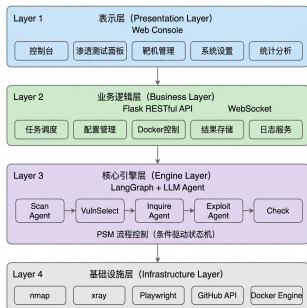


图: AutoPT+ 四层架构图

分层设计

- 表示层：Web Console (Flask + HTML)
- 业务逻辑层：RESTful 接口、Docker 容器管理
- 核心引擎层：LangGraph 状态机、Agent、VulnSelect / Check
- 基础设施层：nmap · xray · Playwright · Docker Engine

提示词结构化与角色差异化

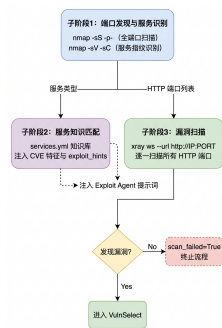
统一 ReAct 基线模板

三个 Agent 共用 _REACT_HEADER / _REACT_FOOTER 骨架，FORMAT RULES 模块禁止 <thinking> 标签，将 Thought 限定为单句。

三个 Agent 的角色边界

- **Scan Agent** (SCAN ONLY, NO EXPLOITATION): 强制 nmap → xray → 结果的有序流程
- **Inquire Agent** (ONLY ReadHTML): 禁止执行命令，输出结构化多步 PoC (STEP N: 格式)
- **Exploit Agent**: 明确 SUCCESS CRITERIA (/etc/passwd、uid=、phpinfo()), 最多 8 次尝试

Scan 阶段细化与提前终止机制



图：动态端口发现流程

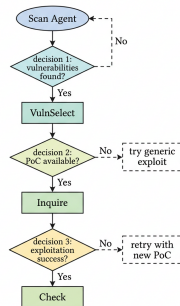
四个子阶段

- 1 端口发现：nmap -p- 全端口 + -sV -sC 服务识别
- 2 服务知识匹配：services.yml 注入 CVE 特征与攻击线索
- 3 漏洞扫描：xray 对所有 HTTP 端口逐一扫描
- 4 结果评估：parse_vuln 解析，为空则写 scan_failed 标志直接终止

上下文压缩与 Check 双层验证

上下文压缩机制

- 即时摘要：关键 token 过滤（漏洞标识、服务指纹、错误信息），截断至 2000 字符
- 三层结构化组装：Final Goal + 漏洞选择 + Scan 摘要
- 容错 PoC 提取：Final Answer → agent_log → ReadHTML 原始返回 → 日志回溯



图：条件驱动的状态转移模型

浏览器扩展工具与 RobustReActParser

三个浏览器扩展工具

- `fill_element`: 定位 input/textarea, 清空后填入文本 (安装向导、登录表单)
- `select_option`: 定位下拉框, 按 value 或文本标签选择
- `wait_for_selector`: 等待元素出现并可见, 支持自定义超时

RobustReActParser 多级容错

原版: 格式偏差 → 直接抛异常终止循环

改进版通过降级策略 (清洗思维链标签 → 标准解析 → 宽松正则 → **Action** 提取 → 模糊匹配 → 格式引导) 将解析失败转为可恢复的中间状态。

Web Console 图形化管理界面

六个功能模块

- 控制台：系统状态总览、OWASP 分类统计
- 漏洞库：20 个 CVE 展示，搜索/难度筛选
- 渗透测试面板：一键发起，实时日志（1.5s 轮询）
- 靶机管理：Docker 容器启/停/销毁监控
- 测试报告：历史记录、成本/Token 多维分析
- 系统设置：API Key、模型参数配置

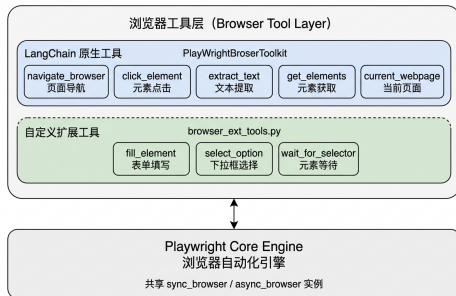


图: 浏览器工具层架构

实验设置

数据集

- 20 个真实 CVE 漏洞（10 简单 + 10 复杂），涵盖 OWASP Top 10 全部类别
- 简单漏洞：1~2 个 HTTP 请求即可打通；复杂漏洞：需先走完安装向导，再对特定模块利用

模型与参数

- 三个 LLM：GPT-4o、GPT-4o-mini、GPT-3.5-turbo，温度参数均固定为 0
- Scan Agent 最多 5 轮迭代，Inquire 3 轮，Exploit 12 轮，PSM 总递归深度上限 30 步

实验流程

- 每漏洞每模型跑 5 次，共 **300** 次独立实验
- 每次实验后销毁重建 Docker 靶机，清空 Agent 上下文
- 原版 AutoPT 数据直接取自原论文^[1]公开结果

RQ1：总体成功率大幅提升

核心结论

- 总体：~25% → **63.67% (+39pp)**
- 简单漏洞均值：~32% → **76.67%**
- 复杂漏洞均值：~17% → **50.67%**
- 原版 60 组中 38 组通过率为 0%，改进版降至仅 **3 组**

维度	原版	AutoPT+	变化
简单 (GPT-4o)	26%	76%	+50pp
简单 (GPT-4o-mini)	56%	90%	+34pp
简单 (GPT-3.5)	14%	64%	+50pp
复杂 (GPT-4o)	26%	50%	+24pp
复杂 (GPT-4o-mini)	18%	58%	+40pp
复杂 (GPT-3.5)	8%	44%	+36pp
总体	~25%	63.67%	+39pp

主要原因

nmap 全端口扫描扩大攻击面；角色隔离提示词减少越权操作

表：各维度成功率对比

RQ2：模型差异分析

三模型成功率排名

- **GPT-4o-mini: 74%**（简单 90%，复杂 58%）——综合最优，ReAct 格式遵循最稳定
- GPT-4o: 63%（简单 76%，复杂 50%）——偏保守，提前放弃比例最高（40.54%）
- GPT-3.5-turbo: 54%（简单 64%，复杂 44%）

架构对弱模型的”兜底”效应

GPT-3.5 原版总体 ~7%，改进版跃升至 **54%**，增幅最大。合理的流程约束和提示词设计可以在相当程度上补偿模型本身能力的不足。

有趣的现象

GPT-4o-mini 表现优于参数规模更大的 GPT-4o——与 AutoPT 原论文观察一致

RQ3: 成本效益分析

指标	原版	AutoPT+	人工
总成本	\$0.99	\$0.31	~\$310
单次成本	\$0.0099	\$0.003109	—
平均耗时/次	161.3s	94.2s	~15min
总体成功率	36%	74%	—

表: 成本效益对比 (GPT-4o-mini, 20 漏洞 × 5 次)

结论

- 费用降低 **69%**
- 耗时缩短 **42%**
- 成功率提升 **38pp**

原因

提前终止省去无效执行；上下文压缩减少 Token 用量

失败原因分析

失败原因	总体	3.5	4o	4o-mini
提前放弃	33.0%	32.6%	40.5%	23.1%
错误的命令	29.4%	28.3%	32.4%	26.9%
上下文限制	22.9%	19.6%	24.3%	26.9%
安全审查拦截	22.0%	19.6%	18.9%	30.8%
工具执行失败	10.1%	13.0%	8.1%	7.7%

表: 109 次失败的原因分布

工具层改进的验证

工具执行失败仅 **10.1%** (最低), 三处改动叠加:

- 浏览器扩展工具补足表单交互
- RobustReActParser 多级容错降级
- RULES 模块明确工具选择判据

主要瓶颈

提前放弃 (33%) 和安全审查拦截 (22%)
尚待解决

工作总结与展望

三大改进与实验结论

- **PSM 流程控制**：Scan 四子阶段 + 提前终止 + 上下文压缩 + Check 双层验证
- **工具与容错**：三个浏览器扩展工具 + RobustReActParser 多级降级
- **Web Console**：六模块图形化管理界面

基于 300 次独立实验：总体成功率 $\sim 25\%$ $\rightarrow$ **63.67% (+39pp)**；成本 -69% ，耗时 -42%

现有不足

- ① **提前放弃 (33%)**：重试建议不区分失败类型
- ② **安全审查拦截 (22%)**：模型拒绝生成攻击性命令
- ③ **覆盖范围局限**：仅 Web 应用层 CVE

未来工作

- 精细化重试策略（按失败类型）
- 引入本地开源模型（如 DeepSeek）
- 扩展 PSM 覆盖完整渗透测试阶段

感谢聆听！

恳请各位老师批评指正